# Incident Response Report

*Healthcare organization | Unauthorized access to electronic protected health information (ePHI)*

Prepared for: Security leadership and incident response stakeholders • Report date: November 1, 2026

**CASE STUDY — SIMULATED INCIDENT. All organizations, event dates, counts, system names and indicators below are illustrative. No forensic evidence or actual incident logs were supplied.**

## Incident overview

| Field | Case-study value |
|---|---|
| **Incident ID** | SIM-IR-2026-001 |
| **Severity / status** | High (illustrative) / Contained; investigation ongoing |
| **Initial detection** | October 20, 2026, 09:10 CDT |
| **Suspected vector** | Phishing-related account compromise; MFA gap |
| **Affected environment** | Cloud email and file repository containing patient administrative records |
| **Incident commander** | CISO / delegated incident response lead |

## 1. Executive summary

On October 20, 2026, anomalous sign-ins and unusually large file-access activity were detected in a hypothetical healthcare organization's cloud environment. Initial triage indicated that an attacker may have used credentials obtained through phishing to access a workforce account and a shared repository containing electronic protected health information (ePHI). The organization's response team revoked active sessions, disabled the account, restricted repository access, preserved evidence and initiated a privacy-led assessment. The illustrated incident is treated as high severity due to potential confidentiality impact, even though the total affected population and whether files left the environment remain unconfirmed.

The key lessons are to enforce phishing-resistant MFA, restrict access to sensitive repositories, alert on anomalous authentication and bulk downloads, and maintain clear coordination among security, privacy, legal and clinical leadership. This report documents a plausible incident-response workflow; actions are described as simulated, not independently verified.

## 2. Timeline of events

| Date/time (CDT) | Event / response | Evidence or status |
|---|---|---|
| **Oct 20, 08:42** | Unusual sign-in from unfamiliar network context | Hypothetical identity log alert |
| **Oct 20, 09:02** | Bulk reads of shared patient-record files | Hypothetical cloud audit trail |
| **Oct 20, 09:10** | SIEM correlates atypical sign-in with abnormal file activity | Illustrative detection timestamp |
| **Oct 20, 09:25** | SOC triages, opens incident and escalates to incident commander | Simulated incident ticket |
| **Oct 20, 09:40** | Sessions revoked; account disabled; repository sharing restricted | Simulated containment actions |
| **Oct 20, 10:15** | Audit logs and relevant endpoint artifacts preserved | Chain-of-custody task initiated |
| **Oct 20, 13:00** | Privacy and legal initiate affected-record scoping | Pending validation |
| **Oct 21, 11:00** | Access reviews and enhanced monitoring deployed | Illustrative short-term remediation |

## 3. Attack narrative and root-cause analysis

Initial access (hypothesis): A staff member receives a convincing message directing them to a counterfeit sign-in page. The attacker obtains a password and uses it to authenticate to a cloud account that lacks effective phishing-resistant MFA. The suspicious sign-in is followed by enumeration of available shared files and a burst of file reads. The attacker attempts to obtain patient administrative information, including names, contact details and appointment-related metadata.

Detection and response: Correlation between atypical authentication context and unusual access volume triggers an alert. The SOC validates the user and session context, escalates the event, and coordinates identity containment, access restriction and evidence preservation. Privacy staff assess whether ePHI was accessed or acquired; legal counsel reviews potential notification duties.

Probable control failures in this simulation: susceptibility to credential phishing, insufficient conditional-access protections, overbroad repository permissions and inadequate download thresholds. This is a working hypothesis —not a confirmed forensic root cause. Confirmation would require identity audit logs, file-access records, endpoint evidence, mail traces and user interview results.

## 4. Indicators of compromise (IoCs) and evidence

| Indicator / artifact | Relevance | Validation / handling |
|---|---|---|
| **Atypical account sign-in** | Unfamiliar device, ASN, geography or user-agent | Compare to historical activity and identity logs |
| **Rapid sequence of file reads** | Possible staging or collection of ePHI | Correlate audit IDs, filenames, volume and permissions |
| **Suspicious phishing URL** | Potential credential-harvesting origin | Extract from email evidence; do not visit directly |
| **New session/token activity** | Possible session persistence | Revoke sessions, check app grants and refresh tokens |
| **Unapproved sharing changes** | Potential external exposure path | Inspect ACL changes and public/external sharing events |

Specific IP addresses, URLs, file hashes and log event IDs: NOT AVAILABLE. No concrete IoC should be blocked or attributed without validation. Evidence register should capture source, UTC timestamp, collection method, SHA-256 hash where applicable, custodian, transfer history and retention requirements.

## 5. Impact assessment

| Area | Preliminary assessment |
|---|---|
| **Confidentiality** | Potential unauthorized access to ePHI; scope and acquisition remain unverified |
| **Integrity** | No confirmed alteration in the simulated narrative; verify with audit logs and integrity checks |
| **Availability** | Short interruption to one account/repository; no organization-wide outage assumed |
| **Patient safety** | No confirmed direct care disruption; clinical leader should validate patient-care dependencies |
| **Business and financial** | Investigation labor, legal review, patient communications and possible remediation costs |
| **Regulatory / contractual** | HIPAA/state/contractual obligations require fact-specific privacy and legal review |

Do not treat potential access as proven exfiltration. Notification timing and recipients depend on the jurisdiction, data type, number of affected people and the documented breach risk assessment. No patient count, financial loss estimate or definitive reportability conclusion is asserted here.

## 6. Mitigation, containment and recovery actions

| Priority | Action | Owner / acceptance criterion |
|---|---|---|
| **Immediate** | Disable compromised account; revoke sessions/tokens; enforce temporary access restrictions | Identity/SOC — no active attacker sessions observed |
| **Immediate** | Preserve identity, email, cloud file and endpoint logs; document custody | Forensics — artifacts hashed and logged |
| **24 hours** | Review mailbox rules, app consents, external sharing and lateral access | SOC/Cloud — suspicious persistence removed |
| **24–72 hours** | Reset credentials, enforce stronger MFA, validate least privilege | IAM — access approved by data owner |
| **24–72 hours** | Scope all sensitive files and recipients; perform legal/privacy assessment | Privacy/Legal — documented decision on notification |
| **Recovery** | Restore appropriate access after validation; monitor recurrence | Operations — owner sign-off and monitoring completed |

## 7. Recommendations and preventive measures

- Within 7 days: require phishing-resistant MFA for high-risk and privileged users; implement conditional access using device compliance and sign-in risk.
- Within 14 days: review and reduce ePHI repository permissions, external sharing, stale accounts and third-party access.
- Within 30 days: tune SIEM detections for impossible travel, token anomalies, large file access and new sharing links; test alert-to-escalation timing.
- Within 30 days: strengthen email protections and targeted phishing training; verify secure reporting paths for suspicious messages.
- Within 45 days: perform a tabletop exercise involving SOC, IAM, privacy, legal, communications and clinical operations.
- Within 60 days: measure mean time to detect/contain, MFA coverage, high-risk sharing exposure and closure of overdue corrective actions.

## 8. Follow-up, governance and closure criteria

The incident commander should maintain an action register with owners, deadlines, evidence links and approvals. Closure requires: (1) validated incident scope and root-cause statement; (2) absence of active unauthorized sessions; (3) documented privacy/legal notification decisions; (4) secure restoration and monitoring sign-off; and (5) completed post-incident review with tracked corrective actions. Reopen the incident if new evidence indicates broader exposure, persistence or patient-safety consequences.

## Method and limitations

This is an educational example adapted to the requested report sections and a general healthcare data-breach scenario. The exact assignment template, incident logs, alerts and forensic findings were not available. Replace illustrative details with supplied case evidence before representing this document as an actual investigation report.